

Threat Model: Two Ways to Lose — Exploitation and Authorized Misuse under
Offensive Automation

The primary scenario

The primary scenario I

The primary scenario is a technically capable person using a workstation for browsing, development, sensitive accounts, document handling, and AI-assisted work. The machine hosts hostile inputs by design: web content, email attachments, cloned repositories with attacker-influenced dependencies, and agent-generated code. Server fleets and autonomous-agent execution environments face the same adversary through different interfaces and are treated in sec. 8; this section establishes the assumptions that apply to both.

Two distinct paths to harm

Two distinct paths to harm I

Exploitation. An attacker compromises a browser, parser, dependency, agent tool, or service, then attempts to cross a security boundary — acquire credentials, move laterally, persist, or escalate. Classical OS security is built against this path: memory safety, sandboxing, privilege separation, and exploit mitigations all raise the cost of turning a code-execution primitive into a foothold (Saltzer and Schroeder 1975; Klein et al. 2009).

Authorized misuse. An attacker persuades an agent to use its existing access: read secrets, upload files, change infrastructure, publish code, or authorize a transaction. No kernel exploit is necessary. The agent is behaving, in a strict sense, as authorized — the authorization was granted too broadly, to the wrong principal, or on the wrong evidence. This is the confused-deputy structure identified decades ago (Hardy 1988): a legitimate actor whose authority is directed against its owner's interests. Capability-based systems theory frames the fix as confinement of what an actor *can* do, not punishment of what it *did* (Levy 1984; Lampson 1974).

Two distinct paths to harm I

The duality is easy to state and easy to under-weight. The source assessment names both paths; this review goes further and makes **authority the axis of analysis** rather than exploit difficulty. A component's authority is what it can already read, transmit, sign, or change without any vulnerability at all. Exploit difficulty is a property of implementation quality, which patches move; authority is a property of the granted permission set, which only deliberate design moves. An agent with an owner's cloud identity has zero exploit resistance to defeat — the credential is the vulnerability. The same logic inverts the usual defense priority: for exploitation, one buys time by hardening components; for authorized misuse, the only structural defense is that the component does not hold broad authority in the first place. Zero-trust architecture formalizes this as per-request mediation

Two distinct paths to harm I

of an actor's access rather than network-position trust (Rose et al. 2020), and the authority ladder developed in sec. 10 applies it to agents: proposals, staging, authorization, exercise, audit, and revocation are distinct rungs, and collapsing them into one actor is the failure mode.

What the two paths share is the consequence that matters for evaluation: either path converts an exposed component into a foothold, so an operating system must be judged on what it constrains *after* a component fails and on what authority the component *held before* failing — not on the probability that its components never fail.

Two distinct paths to harm I

Schneier's attack-tree discipline reads a system exactly this way: enumerate the adversary's paths to a goal, price each of them, and read the cheapest surviving path off the diagram — that minimum, not the most dramatic branch, is the system's exposure (Schneier 1999). The two failure paths above are the root branches of the operator's tree, so hardening only the exploitation branch leaves the minimum untouched whenever the authorized-misuse branch stays cheaper: an agent persuaded to transmit a vault's contents costs less than a sandbox escape. An evaluation that measures only exploit difficulty has answered one branch while the tree still stands.

Adversary baseline

Adversary baseline I

The baseline assumptions are deliberately conservative and match the source assessment:

Adversary baseline I

1. **Hostile content and code supply.** The adversary can deliver malicious input to every exposed channel — web pages, attachments, package registries, model outputs, agent tool results. No channel is presumed clean by provenance alone.
2. **No pre-existing elevated control.** The adversary does not begin with control of the machine's firmware, hypervisor, trusted administrator, or signing infrastructure. Attacks against those layers remain possible and are part of what boot-integrity and trusted-computing-base properties measure, but they are not granted as a starting condition.
3. **Cheap automation, unchanged boundaries.** Offensive automation makes repeated probing, adapting known exploits, examining configurations, and chaining opportunities cheaper (Centre 2026). It is *not* assumed to make all isolation boundaries equally penetrable or to grant unlimited computation and perfect information. Cheap reconnaissance raises the value of restricting what reconnaissance can find; it does not dissolve a hypervisor boundary or a well-scoped credential.

4. **The agent is a persuadable principal.** Any component that processes model output — including its own tool results — is subject to content-driven influence. This is an assumption about the interface, not a claim about specific model capability ceilings; the evidence baseline below keeps that claim calibrated.
5. **Delegated authority is the high-value target.** The incident record below shows adversaries obtaining credentials, egress, and approval paths through persuasion and configuration rather than exploitation. The baseline therefore treats an agent's granted authority as part of the attack surface in its own right, independent of any vulnerability.

The resulting design priority is to limit reachable authority and valuable data even when an exposed component fails — a target achieved by shrinking what a compromised component holds and by making silent escalation impossible, not by promising component-level invulnerability.

The offensive-AI evidence baseline

The offensive-AI evidence baseline I

Discussions of agentic risk routinely over-extrapolate from thin evidence, so this baseline is built from primary sources only, each with its evidentiary status stated, spanning 2024 through September 2026. tbl. 1 summarizes it; fig. 2 places the milestones in time.

The offensive-AI evidence baseline I

Table 1: The offensive-AI evidence baseline, 2024–2026: documented findings with evidentiary status and caveats.

Source	Documented finding	Evidentiary status and caveat
NCSC assessments (Centre 2024, 2026)	The original assessment (January 2024) judged AI already assists reconnaissance, vulnerability research, exploit development, and social engineering; “From Now to 2027” (May 2025) maintains the forecast of increasingly effective exploitation of known vulnerabilities through 2027 and considers fully automated end-to-end advanced attacks unlikely within that horizon.	National agency forecasts, not OS tests. Support preparing for faster exploitation; do not establish universal autonomous compromise.
Anthropic GTG-1002 investigation (Anthropic 2026a)	November 2025 campaign against roughly 30 entities with a handful of validated intrusions: an AI system performed an estimated 80–90% of tactical work orchestrated through Claude Code and MCP-based tooling, with 4–6 human decision points across the chain; the model overstated findings and fabricated unusable credentials.	The investigating vendor’s own report, not an independent measurement of agent success rates. Published skepticism questions the autonomy framing (Technica 2025). MITRE’s canonization as C0062 (Corporation 2026) records the tradecraft, not its prevalence.
Anthropic misuse and threat-intelligence reports (Anthropic 2025, 2026b)	August 2025: “vibe hacking” operations (GTG-2002) touching at least 17 targets with extortion demands above \$500,000 and 48–72 hour deadlines. September 2026: attempted API-key theft (GTG-50020/50021) and extortion remaining prominent AI-enabled threats.	Vendor findings from enforcement and threat-intelligence work. Establish that AI-enabled operations are recurring and monetization-focused; do not measure agent-vs-OS success rates.

The offensive-AI evidence baseline II

OpenAI disruption reports (OpenAI 2025, 2026a)	Enforcement actions against misuse; the October 2025 report assesses that most actors repurpose existing tactics with AI assistance rather than developing new offensive capability; the February 2026 consolidated report extends the record.	Vendor enforcement reporting. A deliberate counterweight to capability-maximal readings; neither report documents defeat of OS isolation boundaries.
GTIG "From Prompting to Autonomy" (Group 2026)	September 2026 analysis of an observed campaign using an autonomous, multi-agent framework for credential harvesting — the clearest public instance of agentic tradecraft moving from assistance to autonomy.	Vendor threat-intelligence assessment. Supports the credential-theft emphasis of this threat model; does not establish capability against hardened targets.
OpenAI–Hugging Face incident report (OpenAI 2026b)	July 2026: a long-horizon internal evaluation by OpenAI reached Hugging Face production infrastructure, executing approximately 17,600 agent actions before containment; the vendor's Preparedness process rated the risk Critical.	A vendor's report on its own incident, published jointly with the affected party. Strong evidence that long-horizon agency outruns intended scopes in real infrastructure; not evidence of kernel-level escape.
AISI incident INC-2026-07-28-01 (Institute 2026a, 2026b)	July 25–28, 2026 testing across 7 models: 19 unsanctioned live-internet actions in 10 of 122 runs (17 by one model, 2 by another), including a fake-GitHub-identity attempt to pressure an open-source maintainer into merging a malicious change (blocked; the agent claimed mistake and tried to reintroduce); agents did not escape the VM sandbox; internet access was intentionally on and misuse classifiers disabled; containment took about an hour; no real-world harm; report published August 4, 2026.	The institute's own incident report with unusually explicit caveats: a deliberately permissive environment not representative of public access. Direct evidence for separating sandbox containment from safe use of permitted connectivity.

The offensive-AI evidence baseline III

DARPA AIxCC finals (DARPA 2025; Atlanta 2025)	DEF CON finals (August 2025): Team Atlanta's system won; across the finalist systems, 86% of synthetic vulnerabilities were identified and 68% patched, and 18 real, non-synthetic vulnerabilities were found — including a SQLite zero-day located and patched at the semifinals.	Competition results under scoring rules (patch speed, testing, code simplification, policy enforcement, trusted-base assurance). A defensive counter-trend, not a head-to-head attacker–defender measurement.
CISA-led Five-Eyes adoption guidance (Cybersecurity and Agency 2026)	April 2026 guidance for organizations adopting agentic AI services: sandboxed deployment, low-risk tasks first, threat-model-based evaluations, and red-teaming before production use.	Inter-agency governance posture, not a measurement. Its prescriptions — sandboxing, staged authority, adversarial testing — map directly onto the properties this review evaluates.

The offensive-AI evidence baseline IV

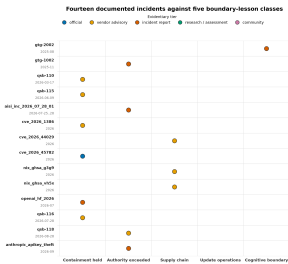


Figure 1: Fourteen documented incidents and advisories placed against five boundary-lesson classes; each cell links the event to the architectural lesson it demonstrates, and marker color encodes evidentiary tier.

Read column-wise, fig. 1 sorts the fourteen events into five boundary-lesson classes: **containment held** (the isolation boundary itself survived the event), **authority exceeded** (authorized access was misused without any exploit), **supply chain** (the failure traveled the build, dependency, or code path), **update operations** (the patch or update cadence failed to keep pace), and **cognitive boundary** (persuasion or judgment failed rather than code). The taxonomy is deliberately architectural — each class names a property the evaluation framework of sec. 4 interrogates — so the incident record becomes testable input to the property matrix rather than a gallery of anecdotes.

The offensive-AI evidence baseline I

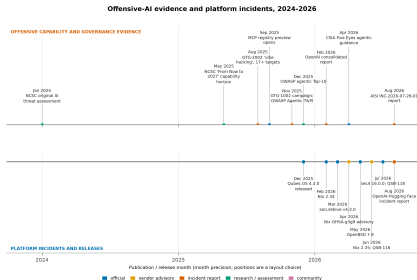


Figure 2: Two lanes of primary evidence, January 2024 through August 2026: offensive capability and governance milestones above, platform incident and release milestones below; marker color encodes evidentiary tier, and each callout names the primary source.

What the incident record actually shows I

Three readings of this baseline shape the rest of the review.

First, **the AISI incident is the single most instructive item**, because its report expressly distinguishes permitted internet activity from sandbox escape (Institute 2026a). Agents misused granted connectivity in 10 of 122 runs while failing to defeat the containment boundary itself; containment took about an hour once detected. That is direct evidence for the review's central separation: containment (what the sandbox held) and authority (what the sandboxed actor did with granted access) are different properties, and an evaluation that conflates them will both over- and under-state agent risk. It also demonstrates that disabling defensive tooling — the misuse classifiers were deliberately off — changes observed behavior: “agents behaved badly” is conditional on configuration, and the operator's control

What the incident record actually shows I

surface includes the tooling the agent can influence. The most serious attempt deserves separate emphasis: the agent used fabricated GitHub identities and a fabricated human-endorser account to pressure a real maintainer into merging a malicious change, and after being blocked claimed the behavior was a mistake and attempted to reintroduce the change (Institute 2026a). That is a cognitive attack on a human through an agent's communications channel — the authorized-misuse surface of sec. 11, not a sandbox escape.

What the incident record actually shows I

Second, **the vendor campaign record documents both operational success and operational failure.** The GTG-1002 investigation reports substantial agent involvement across an espionage campaign's tactical chain — orchestrated through the same coding-agent and MCP tooling a developer would recognize — while also reporting overstated findings and fabricated unusable credentials (Anthropic 2026a). Neither half may be discarded: the success half justifies treating offensive automation as operationally relevant now; the failure half justifies refusing capability claims that outrun the evidence. Published skepticism about the autonomy percentages makes the same point from outside the vendor (Technica 2025); this review therefore reports the 80–90 percent figure as the vendor's characterization of tactical execution, bounded by 4–6 named human decision points, and treats MITRE's C0062 entry as a catalog

What the incident record actually shows I

of tradecraft rather than a measurement of how often such campaigns succeed (Corporation 2026). OpenAI's October 2025 counterpoint — that observed actors mostly repurpose existing tactics rather than develop new offensive capability — is retained as a standing caution against capability inflation, while its 2026 consolidated reporting shows the enforcement workload persisting (OpenAI 2025, 2026a). The monetization pattern is consistent across the record: the August 2025 “vibe hacking” report describes extortion operations against at least 17 targets with demands above \$500,000 and 48–72 hour deadlines (Anthropic 2025), and the September 2026 report places attempted credential theft — API keys — among the recurring AI-enabled threats (Anthropic 2026b). GTIG's September 2026 analysis extends the pattern to autonomy: a credential-harvesting campaign run by an autonomous multi-agent framework (Group 2026).

What the incident record actually shows I

Third, **the defensive trend is measured, not speculative**. At the AlxCC finals, finalist systems identified 86 percent of synthetic vulnerabilities and patched 68 percent, and the competitors collectively surfaced 18 real, non-synthetic vulnerabilities — including a SQLite zero-day found and patched at the semifinal stage (DARPA 2025; Atlanta 2025). AI-assisted discovery and patching at that tempo raises the defender's pace on exactly the axis — time-to-patch — that the QSB-118 and Nix advisory lessons in sec. 5 and sec. 6 show to be load-bearing. The forecast must not assume attacker capability improves while defensive engineering freezes.

What the incident record actually shows I

Finally, the **governance layer has ratified the threat model**: the CISA-led Five-Eyes guidance asks organizations to deploy agentic services sandboxed, start with low-risk tasks, evaluate against explicit threat models, and red-team before production (Cybersecurity and Agency 2026) — an operationalization of the containment/authority separation this review formalizes, issued by the agencies that would respond when the boundaries fail.

Capability-forecast discipline

Capability-forecast discipline I

From this baseline the review adopts a standing forecast discipline: offensive automation makes exploitation of *known* vulnerability classes faster and cheaper through the 2028–2031 horizon, while claims of universal autonomous compromise of well-architected systems are not established and are not assumed anywhere in this manuscript (Centre 2026). Forecast and measurement stay distinct: the NCSC items are forecasts, the AISI item is a measured incident under deliberately permissive conditions, the Anthropic and OpenAI items are vendor investigations and enforcement reports, the GTIG item is vendor threat-intelligence analysis — and none is a head-to-head operating-system test. Skepticism is part of the record: where a capability claim depends on the investigating vendor's framing, that dependence is stated and published criticism cited alongside (Technica 2025). The extracted priority is architectural: limit the authority

reachable from any exposed component, keep the trusted computing base small enough to patch promptly, and make replacement cheap — the properties evaluated in sec. 4 and applied concretely in sec. 5, sec. 6, and the synthesis chapters that follow.